

1.5 Безопасность prompts

Модуль 1. Основы prompt engineering

Оглавление

1. Введение	3
2. Угрозы и риски в prompt engineering	4
3. Типы атак.....	7
4. Методы защиты	10
5. Инструменты безопасности prompts	14
6. Заключение	15

1. Введение

Уважаемые коллеги! Добро пожаловать на лекцию, посвященную важнейшей теме в современном prompt engineering – безопасности промптов. В эпоху стремительного развития искусственного интеллекта и генеративных моделей вопросы безопасности становятся приоритетными для каждого специалиста в этой области.

Сегодня мы погрузимся в мир потенциальных угроз и рисков, с которыми вы можете столкнуться при работе с промптами. Вы узнаете о различных типах атак, которые могут быть направлены на ваши модели, и поймете, почему безопасность промптов – это не просто модный тренд, а критически важный аспект профессиональной деятельности.

Мы рассмотрим реальные примеры уязвимостей, обсудим, как злоумышленники могут использовать слабые места в промптах, и научимся распознавать потенциально опасные ситуации. Особое внимание уделим практическим методам и инструментам защиты, которые помогут вам создавать безопасные и надежные промпты.

Эта информация особенно актуальна в контексте растущего использования больших языковых моделей в различных сферах – от бизнеса до государственного сектора. Понимание принципов безопасной работы с промптами станет вашим важным профессиональным навыком, который поможет избежать серьезных проблем в будущем.

Готовы начать наше погружение в мир безопасной разработки промптов? Давайте вместе разберемся, как защитить наши модели и данные от потенциальных угроз.

2. Угрозы и риски в prompt engineering

Чтобы лучше понять угрозы безопасности prompt engineering, давайте рассмотрим систему технической поддержки с использованием ИИ. Обычно в компании есть некоторая база данных с внутренними документами. Клиент обращается за поддержкой к чат-боту, который дает ему ответ на основе заранее определенной инструкции и с учетом тех данных, которые имеются в базе. В prompt engineering существует серьезная угроза под названием prompt injection - это атака, при которой злоумышленник внедряет в промт команды или инструкции, которые могут заставить модель вести себя непредсказуемо или выполнять нежелательные действия.

3. Prompt injection

Основная опасность заключается в том, что модель может начать игнорировать первоначальные инструкции и следовать указаниям злоумышленника. Например, если вы работаете с системой, которая обрабатывает конфиденциальные данные, злоумышленник может через prompt injection получить доступ к этой информации или заставить систему вести себя небезопасно.

Prompt injection может проявляться в разных формах:

- Внедрение дополнительных инструкций в промт
- Изменение контекста разговора
- Обход защитных механизмов системы
- Манипуляция поведением модели

Особенно важно помнить, что модели ИИ могут быть обмануты через хитрые формулировки промтов, поэтому необходимо всегда проверять, что модель выполняет именно те задачи, которые вы ей изначально поставили.

4. Утечка данных

Data leakage (утечка данных) - это серьезная проблема в prompt engineering, когда конфиденциальная информация случайно или намеренно попадает в промты или ответы модели. Это может привести к серьезным последствиям, включая компрометацию важных данных и нарушение конфиденциальности.

Основные причины утечки данных:

- Неправильная обработка пользовательского ввода
- Отсутствие фильтрации чувствительных данных
- Недостаточная очистка исторических данных модели
- Ошибки в архитектуре системы
- Слабые механизмы защиты данных

Data leakage может проявляться в разных формах:

- Раскрытие персональных данных пользователей
- Утечка коммерческой тайны
- Публикация конфиденциальной корпоративной информации
- Разглашение защищенных данных клиентов
- Компрометация учетных данных

Важно помнить, что даже небольшие утечки данных могут привести к серьезным последствиям. Поэтому необходимо постоянно совершенствовать механизмы защиты и следить за обновлениями в области безопасности данных.

Помните, что защита от утечки данных - это комплексный процесс, требующий постоянного внимания и обновления защитных механизмов по мере появления новых угроз и методов атак.

5. Social engineering через LLM

Другую серьезную угрозу представляет собой Social engineering, при которой злоумышленники используют возможности ИИ для манипулирования людьми и получения конфиденциальной информации.

Основные методы социальной инженерии через LLM:

- Создание убедительных фишинговых сообщений
- Имитация диалога доверенных лиц (руководства, коллег, банков)
- Манипуляция эмоциями для получения доступа к данным
- Распространение дезинформации
- Создание поддельных документов и справок
- Проведение психологических атак

Основные риски, к чему могут привести атаки:

- Кража учетных данных и паролей
- Финансовые мошенничества
- Компрометация корпоративной информации
- Разглашение конфиденциальных данных
- Репутационные потери
- Психологическое давление на сотрудников

Злоумышленники могут использовать LLM для:

- Генерации правдоподобных историй и сценариев
- Создания персонализированных сообщений
- Адаптации под стиль общения жертвы
- Обхода систем защиты
- Масштабирования атак на большое количество людей

Помните, что злоумышленники постоянно совершенствуют свои методы, используя возможности современных ИИ-систем. Поэтому важно регулярно

обновлять защитные механизмы и повышать осведомленность сотрудников о новых угрозах.

Особенно важно внедрить культуру безопасности в организации, где каждый сотрудник понимает свою роль в защите от социальной инженерии и знает, как реагировать на подозрительные ситуации.

При обнаружении признаков социальной инженерии через LLM необходимо:

- Немедленно прекратить взаимодействие
- Сообщить о подозрительной активности
- Задokumentировать все детали инцидента
- Провести анализ произошедшего
- Обновить защитные меры

Помните, что лучшая защита от социальной инженерии - это сочетание технических решений и человеческого фактора, где каждый сотрудник является частью системы безопасности организации.

6. Внедрение косвенного промпта

В prompt engineering существует несколько типов атак, и один из наиболее опасных - это Indirect prompt injection (внедрение косвенного промпта). Давайте разберем, что это такое и как работает.

Внедрение косвенного промпта - это метод, при котором злоумышленник пытается внедрить свой код или команды в модель через косвенные подсказки, а не напрямую. В отличие от прямого внедрения, где атака происходит напрямую через промпт, здесь используются более изощренные способы манипуляции.

Принцип работы такой атаки заключается в том, что злоумышленник может использовать различные техники обхода защитных механизмов модели. Например, он может:

- Использовать метафоры и аналогии, которые модель интерпретирует как прямые команды
- Встраивать инструкции в контекст разговора, маскируя их под обычные фразы
- Применять специальные формулировки, которые модель воспринимает как часть задачи
- Использовать многоэтапные подсказки, где каждый следующий промпт зависит от предыдущего

Основная опасность этой атаки в том, что она сложнее детектируется системами безопасности, так как выглядит как обычный диалог. Злоумышленник может постепенно “настраивать” модель на выполнение нужных действий, не вызывая подозрений.

Для защиты от Indirect prompt injection рекомендуется:

- Тщательно проверять контекст и историю взаимодействия с моделью
- Использовать специальные фильтры для выявления подозрительных паттернов
- Ограничивать возможности модели выполнять потенциально опасные команды
- Применять многоуровневую систему верификации промптов
- Регулярно обновлять защитные механизмы с учетом новых методов атак

Важно помнить, что Indirect prompt injection - это постоянно развивающаяся угроза, и методы защиты также должны совершенствоваться. Поэтому необходимо постоянно следить за новыми техниками атак и адаптировать защитные меры соответственно.

7. Jailbreaking

Jailbreaking (взлом системы безопасности) - это тип атаки в prompt engineering, при котором злоумышленник пытается обойти встроенные ограничения и защитные механизмы языковой модели.

Основная цель jailbreaking - заставить модель игнорировать установленные правила безопасности и выполнять запрещенные действия. Это может включать в себя обход цензуры, выполнение потенциально опасных команд или получение доступа к закрытой информации.

Существует несколько распространенных методов jailbreaking:

- Разбиение опасной команды на несколько безопасных частей
- Применение специальных формулировок, которые модель может интерпретировать иначе
- Манипуляция контекстом разговора для постепенного обхода ограничений
- Использование технических уязвимостей в системе безопасности

Jailbreaking особенно опасен тем, что может привести к:

- Утечке конфиденциальной информации
- Выполнению вредоносных команд
- Нарушению правил использования модели
- Потере контроля над поведением системы
- Юридическим последствиям для пользователей

Для защиты от jailbreaking рекомендуется:

- Тщательно настраивать и регулярно обновлять защитные механизмы модели
- Использовать многоуровневую систему верификации промптов
- Применять специальные фильтры для выявления подозрительных паттернов

- Ограничивать возможности модели выполнять потенциально опасные команды
- Создавать четкие правила поведения и регулярно их обновлять
- Проводить мониторинг подозрительной активности
- Обучать пользователей основам безопасного взаимодействия с моделью

Важно понимать, что jailbreaking постоянно эволюционирует, и злоумышленники находят новые способы обхода защитных механизмов. Поэтому необходимо постоянно следить за новыми техниками атак и своевременно адаптировать защитные меры.

Помните, что успешная защита от jailbreaking требует комплексного подхода, включающего как технические решения, так и обучение пользователей правилам безопасного использования моделей.

8. Методы защиты - Фильтрация ввода и вывода

Ключевым методом защиты в prompt engineering является Фильтрация ввода и вывода, которая помогает предотвратить атаки и несанкционированный доступ к данным. Давайте разберем основные аспекты этой технологии.

Фильтрация ввода (input filtering) - это процесс проверки и обработки данных, поступающих в модель. Она включает в себя:

- Проверку на наличие вредоносных команд
- Обнаружение попыток обхода защитных механизмов
- Анализ контекста запроса
- Выявление подозрительных паттернов
- Ограничение длины и формата входных данных

Фильтрация вывода (output filtering) - это контроль над информацией, которую модель генерирует в ответ. Она помогает:

- Предотвратить утечку конфиденциальных данных

- Избежать генерации вредоносного контента
- Контролировать тон и стиль ответов
- Соблюдать установленные правила и ограничения
- Предотвратить распространение дезинформации

Основные инструменты фильтрации:

- Регулярные выражения - для поиска и замены определенных паттернов в тексте
- Системы машинного обучения - для выявления аномалий и подозрительного поведения
- Контекстный анализ - для понимания намерений пользователя
- Черные и белые списки - для ограничения определенных слов и фраз
- Многоуровневая система проверки - комбинация различных методов фильтрации

Рекомендации по настройке фильтрации:

- Используйте комбинацию различных методов фильтрации
- Регулярно обновляйте базы данных запрещенных слов и паттернов
- Настройте систему так, чтобы она учитывала контекст запроса
- Создайте систему оповещений о подозрительной активности
- Проводите тестирование на проникновение для проверки эффективности фильтров
- Учитывайте культурные и языковые особенности при настройке фильтров

Важные моменты при работе с фильтрацией:

- Необходимо найти баланс между безопасностью и удобством использования
- Чрезмерная фильтрация может привести к ложным срабатываниям
- Недостаточная фильтрация создает риски безопасности
- Система должна быть гибкой и настраиваемой
- Требуется регулярное обновление правил фильтрации

Помните, что фильтрация ввода и вывода - это не панацея, а часть комплексной системы безопасности. Эффективная защита требует сочетания различных методов и постоянного мониторинга системы на предмет новых угроз и способов их обхода.

При настройке фильтров важно тестировать их работу на различных типах данных и учитывать возможные побочные эффекты, чтобы не ограничивать легитимное использование модели.

9. Многоуровневая проверка

Многоуровневая проверка в prompt engineering - это система защиты, которая включает несколько последовательных этапов анализа и фильтрации входных данных. Такой подход значительно повышает безопасность и надежность работы с языковыми моделями.

Первый уровень проверки обычно включает базовую фильтрацию - это первичная обработка запроса, где происходит удаление явно вредоносного контента, проверка на соответствие формату и базовую безопасность. Здесь используются регулярные выражения, черные списки запрещенных слов и фраз.

Второй уровень - это семантический анализ. На этом этапе происходит более глубокий анализ смысла запроса, выявление потенциально опасных паттернов и намерений. Применяются специальные алгоритмы для определения контекста и целей запроса.

Третий уровень - это контекстная проверка. Здесь анализируется история взаимодействия с пользователем, оценивается соответствие текущего запроса предыдущим действиям и общему контексту диалога.

Четвертый уровень - это дополнительная валидация через внешние системы. Это может включать проверку через API специализированных

сервисов безопасности, сравнение с базами данных запрещенного контента и другие внешние источники информации.

Для реализации многоуровневой проверки используются следующие инструменты:

- системы контентной фильтрации
- модули семантического анализа
- библиотеки для работы с контекстом
- API сервисов безопасности
- системы мониторинга и логирования

Рекомендации по внедрению:

- начинайте с базового уровня и постепенно добавляйте новые уровни проверки
- тестируйте каждый уровень отдельно и в комплексе
- документируйте все правила и исключения
- регулярно обновляйте базы данных запрещенного контента
- следите за производительностью системы при добавлении новых уровней

Важно помнить, что каждый дополнительный уровень проверки увеличивает время обработки запроса, поэтому необходимо находить баланс между безопасностью и скоростью работы. Рекомендуется начинать с минимально необходимого набора проверок и постепенно расширять систему защиты на основе анализа реальных угроз и инцидентов.

При возникновении спорных ситуаций полезно внедрить механизм ручной модерации или возможность обращения к оператору для разрешения неоднозначных случаев. Это поможет избежать ложных срабатываний и повысит общую эффективность системы защиты.

10. Инструменты безопасности prompts

Критически важным инструментом в prompt engineering для обеспечения безопасной работы с AI-системами являются Guardrails (защитные ограждения). Это специальные механизмы безопасности, которые помогают контролировать и ограничивать поведение языковых моделей.

Основные функции guardrails:

- предотвращение генерации вредоносного контента
- ограничение доступа к конфиденциальной информации
- контроль качества генерируемых ответов
- соблюдение этических норм и правил
- защита от злоупотреблений системой

В OpenAI Moderation API guardrails реализованы через:

- контентную фильтрацию
- проверку токсичности
- определение чувствительного контента
- анализ потенциально опасных инструкций
- мониторинг подозрительного поведения

Как работают guardrails:

1. Предварительная проверка входных данных
2. Анализ контекста взаимодействия
3. Оценка намерений пользователя
4. Мониторинг поведения модели
5. Применение корректирующих действий

При настройке guardrails важно найти баланс между безопасностью и функциональностью, чтобы система оставалась полезной и эффективной для пользователей. Начните с базовых настроек и постепенно адаптируйте их под конкретные потребности вашего приложения.

11. Заключение

Дорогие коллеги, подводя итоги нашего обсуждения безопасности промптов, хочу подчеркнуть ключевые моменты, которые необходимо помнить при работе с языковыми моделями. Безопасность промптов – это не просто дополнительный аспект, а критически важный компонент при разработке и использовании генеративных моделей. Вы познакомились с основными уязвимостями и узнали, как их предотвращать на этапе создания промптов.

Особое внимание стоит уделить OWASP Top 10 для приложений на базе больших языковых моделей. Этот список помогает систематизировать понимание основных угроз и служит отличным руководством при оценке безопасности ваших решений.

Помните, что безопасность – это не разовое действие, а непрерывный процесс. Необходимо постоянно анализировать и обновлять ваши подходы к созданию промптов, учитывая новые угрозы и уязвимости.

Рекомендую всем присутствующим регулярно пересматривать свои практики работы с промптами, следить за обновлениями в области безопасности и делиться опытом с коллегами. Только совместными усилиями мы сможем обеспечить надежную защиту при работе с языковыми моделями.

Благодарю за внимание.

Материалы:

- Чек-лист по безопасности prompt'a
- Таблица «до/после»
- Набор заданий для самостоятельной тренировки